

Dan Boneh 《Cryptography I》第五课：信息完整性

依据原版讲义 05-integrity-v2-annotated.pdf (52 页) 整理。

主线：完整性 → MAC 安全游戏 → PRF-MAC → ECBC/NMAC → 填充与 CMAC → PMAC → 一次性 MAC → Carter-Wegman。

0. 本课目标

前面几课讨论保密性，本课讨论另一个独立目标：

接收者如何判断消息是否被恶意修改，以及消息是否由持有共享密钥的一方生成？

需要掌握：

1. 完整性与保密性的区别；
2. CRC 为什么不能对抗恶意攻击者；
3. MAC、选择消息攻击和存在性伪造；
4. 安全 PRF 为什么能构造 MAC；
5. tag 长度与猜测攻击；
6. raw CBC-MAC 的扩展攻击；
7. ECBC、NMAC、CMAC、PMAC 的设计目的；
8. 多项式一次性 MAC 的安全证明；
9. Carter-Wegman 如何支持多次认证。

1. 完整性与保密性

1.1 保密性

保密性回答“攻击者能否理解消息内容”，典型工具是：

$$c = E(k, m)$$

1.2 完整性

完整性回答“攻击者能否修改或伪造消息而不被发现”。

应用包括保护系统程序、检测病毒篡改、保护公开网页资源、验证网络报文。

1.3 二者彼此独立

只有加密不一定有完整性；攻击者可能看不懂密文，却能通过位翻转改变解密结果。

只有 MAC 不提供保密性；攻击者能看到消息，只是不能产生合法的修改后标签。

现代通信通常同时需要：

confidentiality + integrity

2. CRC 为什么不是密码学完整性

CRC 适合检测随机错误：

$$t = \text{CRC}(m)$$

但 CRC 没有秘密。攻击者把消息改成 m' 后，可以公开计算：

$$t' = \text{CRC}(m')$$

接收者仍会接受 (m', t') 。

对抗主动攻击者需要攻击者不知道的秘密信息。

CRC 不是 MAC，未加密的普通哈希也通常不是 MAC。

3. 消息认证码 MAC

3.1 定义

MAC 系统：

$$I = (S, V)$$

生成标签：

$$S : \mathcal{K} \times \mathcal{M} \rightarrow \mathcal{T}$$

$$t \leftarrow S(k, m)$$

验证：

$$V : \mathcal{K} \times \mathcal{M} \times \mathcal{T} \rightarrow \{\text{yes}, \text{no}\}$$

3.2 正确性

$$V(k, m, S(k, m)) = \text{yes}$$

3.3 通信过程

Alice 共享密钥 k $t = S(k, m)$ 发送 (m, t)	----->	Bob 共享密钥 k 检查 $V(k, m, t)$ yes: 接受 no : 拒绝
--	------------------	--

MAC 保护完整性和共享密钥意义下的来源认证，不自动隐藏消息。

3.4 MAC 与数字签名不同

- MAC 双方共享同一秘密密钥；
- 双方都能生成合法 tag；
- MAC 通常不提供对第三方的不可否认性；
- 数字签名使用私钥签名、公钥验证。

4. MAC 安全游戏

4.1 选择消息攻击

攻击者可以自适应选择：

$$m_1, m_2, \dots, m_q$$

并获得：

$$t_i \leftarrow S(k, m_i)$$

这称为选择消息攻击（CMA）。

4.2 存在性伪造

攻击者只需产生任意新二元组 (m, t) ，满足：

$$V(k, m, t) = \text{yes}$$

且：

$$(m, t) \notin \{(m_1, t_1), \dots, (m_q, t_q)\}$$

它不必恢复密钥，也不必伪造某条指定消息。

4.3 强不可伪造性

课件采用较强条件：为查询过的消息找到另一个合法 tag 也算伪造。对于确定性 MAC，每条消息通常只有一个 tag，两种定义没有区别。

4.4 优势

$$\text{Adv}_{\text{MAC}}[A, I] = \Pr[\text{产生新的有效消息/tag 对}]$$

这里不是二选一区分游戏，所以无需减去 $1/2$ 。

5. 两个基础攻击

5.1 标签碰撞

若攻击者能找到 $m_0 \neq m_1$ ，使一半密钥满足：

$$S(k, m_0) = S(k, m_1)$$

它查询 m_0 得到 t ，再输出 (m_1, t) ，成功率至少 $1/2$ ，所以 MAC 不安全。

5.2 tag 太短

5 位标签只有 32 种可能：

$$\Pr[\text{猜中}] = 2^{-5}$$

一般地， w 位标签单次猜测成功率为：

$$2^{-w}$$

允许 v 次验证尝试时，粗略成功率为：

$$\frac{v}{2^w}$$

6. 系统文件示例与上下文

可以认证：

$$t_i = S(k, \text{filename}_i \parallel F_i)$$

必须把文件名、路径、版本等上下文一起认证，否则攻击者可能交换两个合法文件。

一般应认证：

$$\text{context} \parallel \text{message}$$

MAC 不自动防重放。旧 (m, t) 仍可能有效；需要把计数器、版本、时间戳或 nonce 纳入认证内容，并检查状态。

7. 安全 PRF 导出安全 MAC

7.1 构造

设：

$$F : \mathcal{K} \times \mathcal{X} \rightarrow \mathcal{Y}$$

是安全 PRF。定义：

$$S(k, m) = F(k, m)$$

$$V(k, m, t) = \begin{cases} \text{yes}, & t = F(k, m) \\ \text{no}, & \text{否则} \end{cases}$$

7.2 安全界

$$\text{Adv}_{\text{MAC}}[A, I_F] \leq \text{Adv}_{\text{PRF}}[B, F] + \frac{1}{|\mathcal{Y}|}$$

7.3 证明直觉

把 $F(k, \cdot)$ 替换为真正随机函数 f 。对未查询的新消息 m , $f(m)$ 是独立均匀的 $\mathcal{Y}$ 中元素, 所以只能以 $1/|\mathcal{Y}|$ 猜中。

若真实 PRF 世界中成功率更高, 就能区分 PRF 和随机函数。

7.4 AES 的限制

AES 只接受 128 位输入:

$$\text{AES}_k : \{0, 1\}^{128} \rightarrow \{0, 1\}^{128}$$

所以直接作为 PRF-MAC 只能认证 16 字节消息。长消息需要扩展构造。

8. 截断 MAC

取 PRF 输出前 w 位:

$$F_w(k, m) = F(k, m)[1 \dots w]$$

猜测项变为:

$$2^{-w}$$

截断节省带宽, 也直接降低抗伪造强度。课程建议 tag 应足够长, 例如至少 64 位; 实际要结合消息量和协议要求。

9. raw CBC-MAC

9.1 构造

把消息分块, 设:

$$x[-1] = 0^n$$

逐块计算:

$$x[i] = F(k, x[i-1] \oplus m[i])$$

直接输出:

$$t = x[L]$$

它类似 CBC 加密, 但初始值固定为 0, 不发送随机 IV, 只输出最终链值。

9.2 为什么 MAC 不能照搬随机 IV

若攻击者可以调整初始值, 也能调整第一块, 使分组密码首个输入不变, 从而转移 tag。MAC 初始处理必须固定并由规范定义。

10. raw CBC-MAC 的一次查询伪造

攻击者查询单块消息 m ，得到：

$$t = F(k, m)$$

构造新消息：

$$m' = m \parallel (t \oplus m)$$

第一块状态：

$$x[0] = t$$

第二块输入：

$$x[0] \oplus (t \oplus m) = t \oplus t \oplus m = m$$

所以最终：

$$x[1] = F(k, m) = t$$

即：

$$\text{rawCBC}(k, m \parallel (t \oplus m)) = t$$

攻击根源是最终内部状态直接暴露为 tag，攻击者可以把它用于控制下一块状态。

11. Encrypted CBC-MAC

先用 k 计算 raw CBC 最终状态 $x[L]$ ，再用独立密钥：

$$t = F(k_1, x[L])$$

攻击者看到的不是内部状态本身，因此不能把 tag 直接作为下一块链值。

k 用于消息链， k_1 用于最终状态。实际可以用 KDF 从主密钥导出不同子密钥，但不能随意复用同一密钥角色。

12. NMAC

设：

$$F : \mathcal{K} \times \mathcal{X} \rightarrow \mathcal{K}$$

内部级联：

$$x[0] = F(k, m[0])$$

$$x[i] = F(x[i-1], m[i])$$

外层使用独立密钥：

$$t = F(k_1, x[L] \parallel \text{fpad})$$

外层 PRF 把内部状态与最终 tag 隔离。

NMAC 不常直接基于 AES，因为级联可能逐块改变密钥，导致反复计算 AES 密钥扩展。NMAC 是 HMAC 的理论基础。

13. ECBC 与 NMAC 安全界

13.1 ECBC

$$\text{Adv}_{\text{PRF}}[A, F_{\text{ECBC}}] \leq \text{Adv}_{\text{PRF}}[B, F] + \frac{2q^2}{|\mathcal{X}|}$$

需要：

$$q \ll |\mathcal{X}|^{1/2}$$

13.2 NMAC

$$\text{Adv}_{\text{PRF}}[A, F_{\text{NMAC}}] \leq qL \text{Adv}_{\text{PRF}}[B, F] + \frac{q^2}{2|\mathcal{K}|}$$

需要：

$$q \ll |\mathcal{K}|^{1/2}$$

若要求生日项低于约 2^{-32} ，AES 的例子给出 $q < 2^{48}$ ；3DES 因 64 位分组，只约为 $q < 2^{16}$ 。

14. 扩展性质与生日攻击

若两个前缀碰到相同内部状态：

$$F_{\text{BIG}}(k, x) = F_{\text{BIG}}(k, y)$$

追加同一后缀可能仍相等：

$$F_{\text{BIG}}(k, x \parallel w) = F_{\text{BIG}}(k, y \parallel w)$$

攻击者查询约 $|\mathcal{Y}|^{1/2}$ 个随机消息，根据生日悖论找到 tag 碰撞，再查询一侧追加后缀的 tag，便可把它转移到另一侧未查询消息。

所以安全界中的生日项对应真实攻击。

15. MAC 填充必须可逆

简单补零可能导致：

$$\text{pad}(m) = \text{pad}(m \parallel 0)$$

安全填充必须满足：

$$m_0 \neq m_1 \implies \text{pad}(m_0) \neq \text{pad}(m_1)$$

ISO 10* 填充附加一个 1，再补 0：

1 0 0 ... 0

若消息已恰好完整，也添加一个新的完整填充分组。

16. CMAC

CMAC 是 NIST 标准化的 CBC-MAC 变体。

- 最后一块完整：异或一个派生子密钥；
- 最后一块不完整：先做 10^* 填充，再异或另一个子密钥；
- 然后执行最后一次分组密码运算并输出 tag。

两种末块情况使用不同子密钥，解决长度歧义并阻止扩展攻击。

标准通常约定完整末块用 K_1 ，不完整末块用 K_2 。课件图中的下标可能相反，关键是两种情况分离。子密钥由主密钥按规范派生。

17. PMAC：并行 MAC

第 i 块先加入位置掩码：

$$m[i] \oplus P(k, i)$$

再独立计算：

$$y[i] = F(k_1, m[i] \oplus P(k, i))$$

各块结果异或汇总，再通过最终 PRF 得到 tag。

位置掩码把内容与位置绑定；否则交换两个块不会改变简单异或汇总结果。

每个块只依赖当前内容、位置和密钥，所以可以并行。

安全界：

$$\text{Adv}_{\text{PRF}}[A, F_{\text{PMAC}}] \leq \text{Adv}_{\text{PRF}}[B, F] + \frac{2q^2 L^2}{|\mathcal{X}|}$$

需要：

$$qL \ll |\mathcal{X}|^{1/2}$$

18. PMAC 的增量更新

若只修改第 i 块，可以从旧汇总中移除旧贡献并加入新贡献：

$$z = F^{-1}(k_1, t)$$

$$z' = z \oplus F(k_1, m[i] \oplus P(k, i)) \oplus F(k_1, m'[i] \oplus P(k, i))$$

$$t' = F(k_1, z')$$

因此无需重新处理整条消息。该公式用于理解增量性，具体实现应遵循正式 PMAC 标准。

19. 一次性 MAC

一次性 MAC 只允许攻击者获得一条消息的合法 tag：

$$t_1 = S(k, m_1)$$

随后攻击者输出不同二元组 $(m, t) \neq (m_1, t_1)$ 。

$$\text{Adv}_{\text{1MAC}}[A, I] = \Pr[\text{伪造成功}]$$

一次性限制类似 OTP，允许得到不依赖计算困难假设、对无限计算攻击者仍安全的快速构造。

20. 多项式一次性 MAC

20.1 参数与构造

选择大素数 p ，课件示例：

$$p = 2^{128} + 51$$

密钥：

$$(a, b) \in \mathbb{F}_p^2$$

消息：

$$m = (m[1], \dots, m[L])$$

消息多项式：

$$P_m(x) = x^{L+1} + m[L]x^L + \dots + m[1]x$$

tag：

$$S((a, b), m) = P_m(a) + b \pmod{p}$$

20.2 安全定理

对 $m_1 \neq m_2$ ：

$$\Pr[S((a, b), m_1) = t_1 \mid S((a, b), m_2) = t_2] \leq \frac{L}{p}$$

20.3 证明

对任意 a ，恰有一个 b 满足：

$$P_{m_2}(a) + b = t_2$$

因此该事件概率为 $1/p$ 。

若两条 tag 同时成立，两式相减：

$$P_{m_1}(a) - P_{m_2}(a) = t_1 - t_2$$

这是非零的至多 L 次多项式方程，最多有 L 个根。两式同时成立概率至多 L/p^2 ，所以条件概率：

$$\frac{L/p^2}{1/p} = \frac{L}{p}$$

这是信息论安全结论。

21. Carter-Wegman MAC

一次性 MAC 很快，但密钥不能直接重复。Carter-Wegman 用 PRF 掩码支持多次认证。

21.1 构造

设 (S, V) 是一次性 MAC， F 是安全 PRF，总密钥为 (k_1, k_2) 。

选择随机：

$$r \leftarrow \{0, 1\}^n$$

计算：

$$u = S(k_2, m)$$

$$t = F(k_1, r) \oplus u$$

输出：

$$\text{CW}((k_1, k_2), m) = (r, F(k_1, r) \oplus S(k_2, m))$$

21.2 验证

$$u' = F(k_1, r) \oplus t$$

再运行：

$$V(k_2, m, u')$$

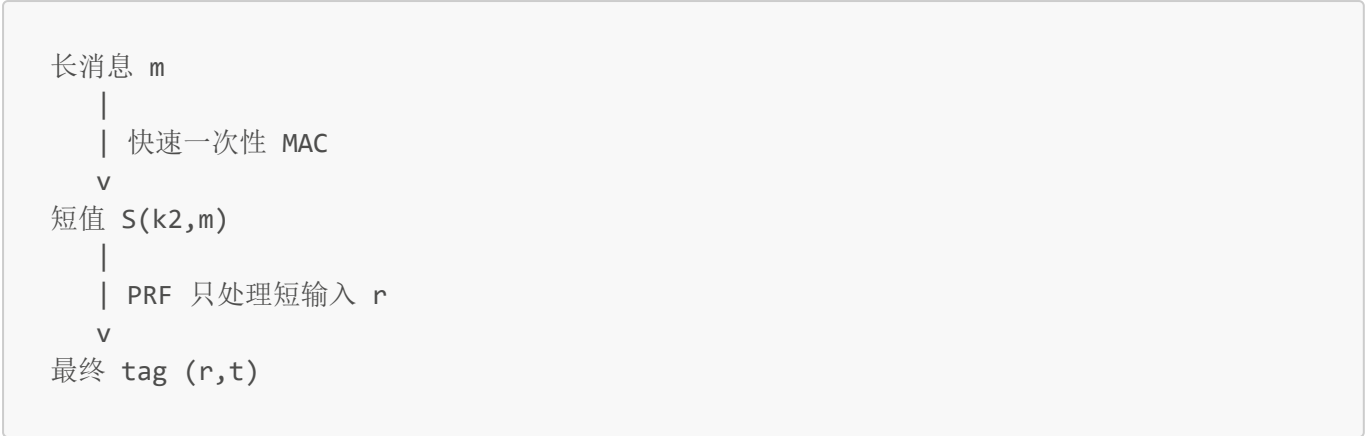
即：

$$V(k_2, m, F(k_1, r) \oplus t)$$

21.3 安全直觉与性能

若 r 不重复， $F(k_1, r)$ 像独立随机掩码，攻击者看不到真正的一次性 tag。

重复 r 会重复掩码，所以随机空间必须足够大。



长消息由快速代数 MAC 处理，较慢 PRF 只处理短输入。

22. 构造对比

构造	底层原语	并行性	主要特点
PRF-MAC	安全 PRF	取决于 PRF	证明最直接
raw CBC-MAC	PRP	否	变长消息有扩展攻击
ECBC-MAC	两个 PRP 密钥	否	最后加密隐藏链值
NMAC	PRF	否	HMAC 理论基础
CMAC	分组密码	否	标准化、派生末块子密钥
PMAC	PRF/PRP	是	高吞吐、可增量更新
多项式一次性 MAC	有限域运算	可优化	信息论一次性安全
Carter-Wegman	一次性 MAC + PRF	较好	支持多次认证

23. 实现与协议注意事项

23.1 固定时间比较

tag 应使用固定时间比较。首个错误字节即返回可能通过时间泄露正确前缀。

23.2 先验证再使用

消息必须在验证成功后才产生安全敏感效果。

23.3 认证所有解释字段

$$\text{version} \parallel \text{type} \parallel \text{length} \parallel \text{sequence} \parallel \text{message}$$

23.4 密钥分离与标准方案

加密密钥和 MAC 密钥应分离；内部子密钥按规范派生。现实系统优先使用 AES-GCM、ChaCha20-Poly1305 等 AEAD，不自行组合。

24. 常见误区

1. CRC 能提供密码学完整性。错误，攻击者可重算。
2. MAC 会隐藏消息。错误，MAC 不提供保密性。
3. 必须恢复密钥才算攻破。错误，任意新有效二元组就是伪造。
4. 任意短 tag 都安全。错误， w 位 tag 猜中率为 2^{-w} 。
5. AES 可直接认证任意长消息。错误，AES 只接受 128 位输入。
6. CBC 最后一块直接作为 tag 一定安全。错误，变长 raw CBC-MAC 有扩展攻击。
7. 填充只需补齐长度。错误，填充必须单射。
8. MAC 中应发送随机 IV。错误，攻击者可控初始状态可能导致伪造。
9. MAC 自动防重放。错误，需要认证并检查序列号等状态。
10. PMAC 中块顺序无关。错误，位置掩码绑定内容与位置。
11. 一次性 MAC 密钥可以复用。错误，定理只保证一次。
12. Carter-Wegman 的 r 可频繁重复。错误，重复会复用 PRF 掩码。
13. MAC 与数字签名相同。错误，MAC 使用共享密钥。

25. 必会公式

25.1 正确性

$$V(k, m, S(k, m)) = \text{yes}$$

25.2 PRF-MAC

$$S(k, m) = F(k, m)$$

$$\text{Adv}_{\text{MAC}} \leq \text{Adv}_{\text{PRF}} + \frac{1}{|\mathcal{Y}|}$$

25.3 tag 猜测

$$\Pr[\text{猜中 } w \text{ 位 tag}] = 2^{-w}$$

25.4 raw CBC-MAC

$$x[-1] = 0^n, \quad x[i] = F(k, x[i-1] \oplus m[i])$$

25.5 扩展伪造

$$\text{rawCBC}(k, m \parallel (t \oplus m)) = t$$

其中 $t = F(k, m)$ 。

25.6 可逆填充

$$m_0 \neq m_1 \implies \text{pad}(m_0) \neq \text{pad}(m_1)$$

25.7 多项式一次性 MAC

$$S((a, b), m) = P_m(a) + b \pmod{p}$$

$$\Pr[\text{伪造成功}] \leq \frac{L}{p}$$

25.8 Carter-Wegman

$$\text{CW}((k_1, k_2), m) = (r, F(k_1, r) \oplus S(k_2, m))$$

验证:

$$V(k_2, m, F(k_1, r) \oplus t)$$

26. 自测题

1. CRC 为什么不能抵抗主动攻击者?
2. MAC 安全游戏中攻击者有何能力? 何时成功?
3. 为什么存在性伪造是很强的要求?
4. 32 位 tag 单次猜中率是多少? 2^{20} 次尝试后的粗略概率是多少?
5. PRF-MAC 安全界为什么有 $1/|\mathcal{Y}|$?
6. 完整推导 raw CBC-MAC 的一次查询伪造。
7. ECBC 最后一次独立加密解决什么问题?
8. NMAC 为什么不常直接使用 AES?
9. 为什么碰撞加扩展性质可产生伪造?
10. 简单补零为什么不安全?
11. CMAC 为什么区分完整与填充末块?
12. PMAC 的位置掩码有什么作用?
13. PMAC 为什么可以并行?
14. 多项式根数量如何导出 L/p 上界?
15. Carter-Wegman 如何支持多次认证?
16. 如何验证 Carter-Wegman 标签 (r, t) ?
17. 为什么 MAC 不能自动防重放?

27. 参考答案

1. CRC 无秘密, 攻击者可修改后重算。
2. 攻击者可查询自选消息 tag; 输出未得到且验证通过的新二元组即成功。
3. 无需恢复密钥或伪造指定消息, 任意新有效二元组就算攻破。
4. 单次 2^{-32} ; 2^{20} 次粗略为 2^{-12} 。
5. 即使是真随机函数, 仍可能以 $1/|\mathcal{Y}|$ 猜中新消息 tag。
6. 查询 m 得 $t = F(k, m)$; 第二块输入为 $t \oplus (t \oplus m) = m$, 最终仍为 t 。
7. 隐藏最终内部状态, 阻止把 tag 当作后续链值。
8. NMAC 逐块改变密钥, AES 需反复做密钥扩展。
9. 相同内部状态追加同一后缀仍相同, 一侧扩展 tag 可转移给另一侧。
10. m 与 $m \parallel 0$ 可能补成同一串; 填充必须单射。
11. 不同子密钥分离两种编码域, 并阻止扩展。
12. 将内容与位置绑定, 防止交换分组。
13. PMAC 每块只依赖该块、位置和密钥; CBC-MAC 依赖前一链值。
14. 差多项式最多有 L 个根, 随机 a 命中率至多 L/p 。

15. 用新随机 r 的 PRF 输出掩盖底层一次性 tag。
16. 计算 $u = F(k_1, r) \oplus t$, 再检查 $V(k_2, m, u)$ 。
17. 旧消息/tag 仍合法; 需认证并检查序列号、nonce 或版本状态。

28. 一页式总结

完整性: 检测恶意修改和伪造, 不自动隐藏消息

MAC:

$t = S(k, m)$
 $V(k, m, t) \rightarrow \text{yes/no}$
 CMA 后仍不能产生新有效消息/tag 对

PRF-MAC:

$t = F(k, m)$
 $\text{Adv_MAC} \leq \text{Adv_PRF} + 1/|Y|$

raw CBC-MAC:

最终内部状态直接作为 tag
 变长消息存在一次查询扩展伪造

ECBC: 用第二密钥加密最终链值

NMAC: 内层级联 + 外层 PRF, 是 HMAC 理论基础

CMAC: 完整/不完整末块使用不同派生子密钥

PMAC: 位置掩码使各块可并行和增量更新

一次性多项式 MAC:

$S((a, b), m) = P_m(a) + b \bmod p$
 信息论伪造率 $\leq L/p$

Carter-Wegman:

$(r, F(k_1, r) \text{ XOR } S(k_2, m))$
 快速处理长消息, PRF 掩码支持多次认证

29. 学习建议

第一遍: 区分保密性、完整性、CRC、MAC 和数字签名。

第二遍: 不看笔记复述 MAC 安全游戏。

第三遍: 独立推导 raw CBC-MAC 一次查询攻击。

第四遍: 比较 ECBC、NMAC、CMAC、PMAC。

第五遍: 完成 L/p 概率证明和 Carter-Wegman 验证公式。

最后完成第 26 节自测题, 重点检查第 6、9、11、14、15、16 题。

范围说明: 本讲末尾只预告 HMAC; 哈希函数、Merkle-Damgard 与 HMAC 详细安全性属于后续课程。